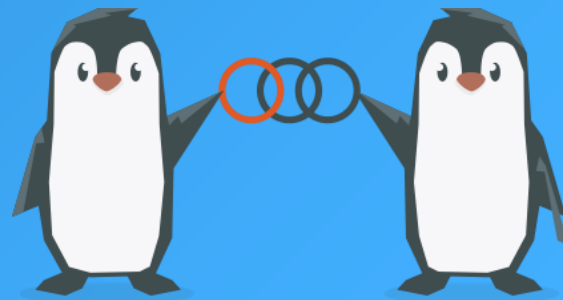


OpenChain SBOM WG

2026-04-22



Anti-Trust Policy Notice

- Linux Foundation meetings involve participation by industry competitors, and it is the intention of the Linux Foundation to conduct all of its activities in accordance with applicable antitrust and competition laws. It is therefore extremely important that attendees adhere to meeting agendas, and be aware of, and not participate in, any activities that are prohibited under applicable US state, federal or foreign antitrust and competition laws.
- Examples of types of actions that are prohibited at Linux Foundation meetings and in connection with Linux Foundation activities are described in the Linux Foundation Antitrust Policy available at <http://www.linuxfoundation.org/antitrust-policy/>. If you have questions about these matters, please contact your company counsel, or if you are a member of the Linux Foundation, feel free to contact Andrew Updegrove of the firm of Gesmer Updegrove LLP, which provides legal counsel to the Linux Foundation.

Celebrating the Start of the Public Comment Period!



SBOM Document Quality Guide

Compliance Management Guide for the Supply Chain

An official guide published by the OpenChain Project (www.openchainproject.org)

Version: 2026.04.03

1

THE LINUX FOUNDATION PROJECTS

ADOPT OUR STANDARDS REFERENCE LIBRARY WEBINARS PARTICIPATE AMBASSADORS PARTNERS F

Public Comment Period – SBOM Document Quality Guide – Ends 31st May 2026

By board | 2026-04-03 | Featured, News

Public Comment Period – SBOM Document Quality Guide – Ends 31st May 2026

Happening Now:
We are announcing a public comment period for the SBOM Document Quality Guide that has been developed by the OpenChain SBOM Work Group.

Document: [SBOM Document Quality Guide](#)

Why This Is Happening:
The OpenChain Project has a formal process for public comment periods related to important releases like the SBOM Document Quality Guide. These public comment periods signify that we have completed work on a topic, and now want to ensure people outside of the OpenChain Project and its work groups can provide additional input as needed. After the public comment period, we formally release the relevant document.

How to write comments:
We are accepting comments via our SBOM Work Group mailing list and through our monthly calls. The recommended way of providing feedback is via the mailing list.
You can read the full process (and our other processes) here: <https://lnkd.in/d7D4RmgN>

You can find the URL for the mailing list here: https://lnkd.in/dEUF_tzK

You can find our SBOM Work Group calls (and all other OpenChain calls) list here: <https://lnkd.in/dcA8pDR9>
A big thanks to @Norio Kobota and the whole of the OpenChain Project SBOM Work Group work on this document.

Mary Meixia Wang • 100
Executive Director @ Open Chain Project, The Linux Foundation

Public Comment Period – SBOM Document Quality Guide – Ends 31st May 2026

Happening Now:
We are announcing a public comment period for the SBOM Document Quality Guide that has been developed by the OpenChain SBOM Work Group.

SBOM Document Quality Guide:
<https://lnkd.in/dhe3grvW>

Why This Is Happening:
The OpenChain Project has a formal process for public comment periods related to important releases like the SBOM Document Quality Guide. These public comment periods signify that we have completed work on a topic, and now want to ensure people outside of the OpenChain Project and its work groups can provide additional input as needed. After the public comment period, we formally release the relevant document.

How to write comments:
We are accepting comments via our SBOM Work Group mailing list and through our monthly calls. The recommended way of providing feedback is via the mailing list.
You can read the full process (and our other processes) here: <https://lnkd.in/d7D4RmgN>

You can find the URL for the mailing list here: https://lnkd.in/dEUF_tzK

You can find our SBOM Work Group calls (and all other OpenChain calls) list here: <https://lnkd.in/dcA8pDR9>

 **SBOM Document Quality Guide**
docs.google.com

<https://openchainproject.org/news/2026/04/03/public-comment-period-sbom-document-quality-guide-ends-31st-may-2026>

THANK YOU MESSAGE TO CONTRIBUTORS

Appreciation for Contributions

Express heartfelt thanks to all contributors for their time, expertise, and valuable feedback that improved the document.

Ongoing Collaboration

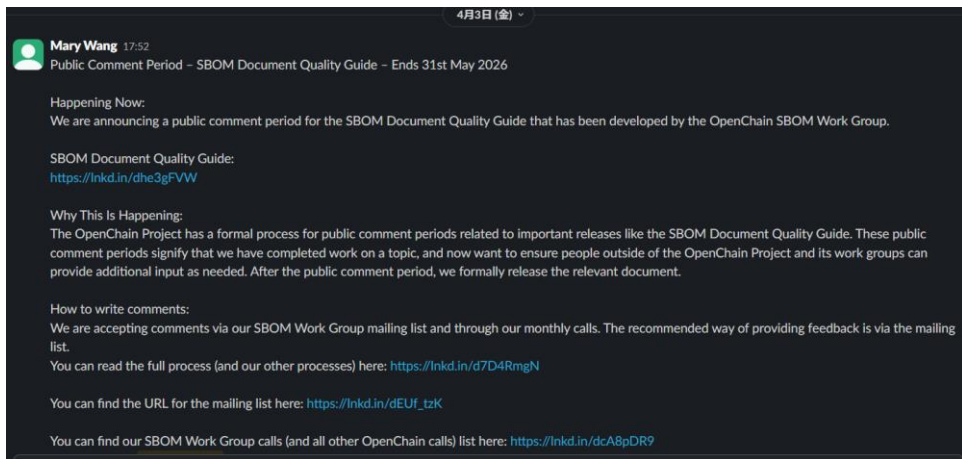
Greatly appreciate your continued engagement and open dialogue as we further refine and update this shared guidance.

Balanced Forward Outlook

While discussions will continue and future updates lie ahead, for now we pause and look forward to receiving thoughtful public comments.

🤝 Outreach Activities

Our outreach efforts utilize established community channels such as the OpenChain website, LinkedIn, and Slack, reaching aligned initiatives including OpenSSF SBOM Everywhere, SPDX Project, and the Eclipse Foundation ORC etc.



Still Confirming ...

Appendix.1 Acknowledgments

This list acknowledges those who have provided edits, feedback, and comments.
The names are arranged in alphabetical order.

Akihiko Takahashi
Alberto Pianon
Anthony Harrison
Ayumi Watanabe
Fuminobu Takeyama
Gary O'Neill
Itaru Hosomi
Jari Koivisto
Kate Stewart
Kiyoshi Owada
Kouki Hama
Marc-Etienne Vargenau
Nobuyuki Tanaka
Norio Kobota
Philippe Ombredanne
Satoru Koizumi
Shane Coughlan
Tadayuki Osaki
Takashi NINJOUJI
Tsukasa Yobo
vivek kumar sahu
Yoshiyuki Ito
Yosuke Hirano
Yumi Tomita
조명식

Appendix: Contributor List

If your name is missing and if there are any errors in the spelling or format of your name, please let us know or correct it directly.

<https://docs.google.com/document/d/1iuXX8j10N70dfce1-CZFWhW6S2jEqc--flcCgXMMdjg/edit?pli=1&tab=t.0#heading=h.itfupkdp7y0l>

Open Source Summit North America 2026, May 18-21

- Complying With Regulatory SBoM Requirements Using the Yocto Project - Joshua Watt, Garmin
<https://sched.co/2JQrD>
- The Architecture of Accountability: Transparency in Software - Hayden Blauzvern, Google
<https://sched.co/2JQrY>
- Verification Toward Applying SLSA in Automotive IVI Software Development - Yuta Kiyoumi & Takashi Ninjouji, Honda Motor Co., Ltd.
<https://sched.co/2JQrq>
- From Compliance To Code: The Cyber Resilience Act, SBOMs, DevTeams and YOU! - Marcus Ross, Hamburg Port Authority AöR & Peter Dickten, dcs-fuerth Germany
<https://sched.co/2JQsE>
- SPDX and SBOM Work for the Linux Kernel - Tim Bird, Sony Electronics
<https://sched.co/2JQtC>
- Package Managers Metadata and Cross Ecosystem Projects in the Era of SBOMs - Damián Vicino, Datadog
<https://sched.co/2JQtI>
- Software Supply Chain Management With the Yocto Project - Joshua Watt, Garmin
<https://sched.co/2JQxz>
- Driving Strategic Value Through Open Source: OSPOs and R&D Organizations in the Era of the CRA - Georg Kunz & David Östman, Ericsson Software Technology
<https://sched.co/2JQxA>

Also SPDX meetup, OpenChain meetup might be held on site.

<https://events.linuxfoundation.org/open-source-summit-north-america/>

We already have a public comment from Ibrahim-san

No	From	Comments Abstract	The relevant text	Relevant Clauses	Our Response
1	Ibrahim Haddad	CRA requires retention for ten years or the product support period, whichever is longer, but this is not addressed in the guide.	The retention obligations are not addressed. The CRA mandates ten years or the product support period, whichever is longer.	Main: 6.1, Sub: Add to Chapter 3	This guide discusses quality considerations for handling general SBOM documents, so it does not address CRA-specific retention periods and does not need to include them as requirements in Chapter 3.
2	Ibrahim Haddad	The relationship between reporting deadlines (e.g., 24h/72h) and SBOM quality requirements should be clarified.	The CRA's vulnerability reporting timelines (24h, 72h, 14 days, one month) should be connected to SBOM quality requirements, as the SBOM is the instrument that enables compliance with those timelines.	Main: 6.1, Sub: Add to Chapter 3	This guide does not claim that meeting the Quality Guide requirements means full compliance with the CRA. It only defines requirements related to the quality of the documented content, not regulatory compliance.
3	Ibrahim Haddad	The text uses "SHALL" wording in CISA 2025 guidance, but it is unclear whether this is a draft or a final version.	The CISA 2025 guidance is presented with mandatory SHALL language without disclosing whether it has been finalized or remains a draft.	6.3	At this stage, CISA 2025 is still in draft form, and this should be clearly noted. We will update this guide once the reference is formally published.
4	Ibrahim Haddad	Traceability obligations for critical infrastructure operators are not reflected.	China's Cybersecurity Law and associated regulations impose SBOM-aligned traceability obligations on critical infrastructure operators and are not addressed in the guide.	6.0	
5	Ibrahim Haddad	It should be stated that the rule applies only to U.S. federal procurement and has no direct force on the private sector.	The scope of the US EO 14028 should be clarified; it is limited to US federal procurement and carries no direct enforcement mechanism for the broader private sector.	6.2	
6	Ibrahim Haddad	Validation, update frequency, distribution control, and retention are not described.	The guide covers SBOM document quality at the moment of exchange but does not address lifecycle management: verification, update cadence, sign-off, distribution controls, and retention. These are critical phases in the lifecycle of the SBOM covered in my report	Add to Chapter 3	
7	Ibrahim Haddad	Section 3.4 covers only the initial delivery.	The obligation to generate a new SBOM with every software update is not mentioned. Section 3.4 covers initial delivery timing only.	3.4	
8	Ibrahim Haddad	Guidance is needed on which department owns the SBOM process.	Organizational accountability is treated only as a document field problem. I believe the guide should address or provide guidance on which function owns the SBOM process, not just which fields to populate.	Add to Chapter 3	
9	Ibrahim Haddad	Configuration data that includes vulnerability information should be access-controlled.	The confidentiality guidance in section 3.7 prohibits redistribution restrictions, which conflict with the security practice of controlling access to component inventories that reveal unpatched vulnerabilities. (I've covered this topic in my report)	3.7	
10	Ibrahim Haddad	Build integration and binary analysis should also be included.	Verification methods in section 3.6 are limited to digital signatures. However, other methods exist, such as Build system integration, hash comparison, and binary analysis, which are established techniques that should be mentioned or included.	3.6	
11	Ibrahim Haddad	It is unclear where to start.	The guide does not offer a phased adoption path or prioritization guidance. Organizations at different maturity levels have no way to identify where to start. I believe there will be high value in providing guidance on the adoption path.	Add to Chapter 2	
12	Ibrahim Haddad	Transitive dependency coverage should be a SHALL requirement because it is a major vulnerability source.	Transitive dependency coverage is a SHOULD. Given that major vulnerabilities consistently originate in transitive dependencies, this should be a SHALL with explicit depth guidance.	3.3	
13	Ibrahim Haddad	VEX is not mentioned	VEX is not mentioned. It is an established complement to SBOM for vulnerability management and is natively supported in CycloneDX 1.4 and later.	Add to Chapter 3	
14	Ibrahim Haddad	Verification is needed after integrating multiple SBOMs.	The guide does not address the topic of SBOM composition and merging. This is a common challenge in multi-tier / complex sw supply chains and a potential practical gap for the intended audience. A merged SBOM should be validated after composition to confirm that no data was lost, no relationships were broken, and no duplicate components were introduced. The guide's quality criteria in section 3 apply to individual SBOM documents but are not explicitly extended to cover the output of a merge operation.	Add to Chapter 3	

https://docs.google.com/spreadsheets/d/13nMWvqYJV8gpZq_7L9rS62kgNRX6G8BucLLu9s8fR_M/edit?gid=0#gid=0

